SECCIÓN 7.6

Scores, enriquecimientos y evidencia contradictoria

Temas de esta sección:

- Qué son scores, clasificaciones y enriquecimientos automáticos
- Cómo leer confidence, severity, user risk, device risk y reputación
- Por qué un score alto no es una conclusión — preguntas útiles
- Errores comunes al usar scores: escalar por score, cerrar por score, ignorar evidencia
- Caso: evidencia contradictoria en archivo (EDR vs VirusTotal)
- Caso: reputación maliciosa en IP cloud compartida
- Caso: IA vs evidencia técnica

7.6 | Scores y enriquecimientos: cómo leerlos

SCORE

Número o categoría que orienta prioridad.

Ejemplos:
- Risk 85/100
- User Risk: High
- Device Risk: Medium

No explica todo por sí solo. Hay que buscar qué eventos lo alimentan y qué peso tiene cada señal.

CLASIFICACIÓN

Etiqueta automática aplicada a una alerta o entidad.

Ejemplos:
- Likely benign
- Suspicious
- Malware
- Possible C2

Debe revisarse la evidencia detrás. Puede estar sobreponderando un factor.

ENRIQUECIMIENTO

Contexto agregado automáticamente.

Ejemplos:
- Reputación del hash o dominio
- País y ASN de la IP
- MITRE ATT&CK asociado
- Primer visto en el entorno
- Campaña maliciosa relacionada

Ayuda, pero puede ser incompleto o desactualizado.

7.6 | Cómo leer confidence, user risk, device risk y reputación

Campos frecuentes en alertas enriquecidas — qué significan y cómo usarlos:

Campo	Qué significa	Cómo usarlo
`Confidence: High / Low`	Qué tan seguro está el modelo de su clasificación.	*→ High + evidencia sólida → mayor peso. Low → revisar evidencia cruda antes de actuar.*
`Severity: Critical / High / Medium / Low`	Prioridad sugerida según reglas o modelo.	*→ Punto de partida, no decisión final. Un Severity:Low puede esconder caso crítico si el activo es importante.*
`User Risk: High`	El modelo detectó comportamiento anómalo acumulado del usuario.	*→ ¿Qué eventos alimentan el score? ¿El usuario es técnico? ¿Hay contexto operativo que lo explique?*
`Device Risk: Medium`	El dispositivo tiene señales de riesgo: parches, configuración, comportamiento.	*→ Combinar con actividad del usuario. Risk alto sin alertas activas puede no requerir acción inmediata.*
`First Seen: Today`	El indicador no tiene historial en el entorno.	*→ Señal relevante: dominio sin historial que genera beaconing es más sospechoso que uno visto hace años.*
`Reputación: Malicious`	Una fuente de TI marcó el indicador como malicioso.	*→ ¿La fuente tiene fecha? ¿El indicador es IP cloud compartida? ¿Coincide con evidencia técnica propia?*

7.6 | Por qué un score alto no es una conclusión

Preguntas útiles antes de decidir

- ¿Qué eventos alimentan el score?
- ¿Qué peso tiene cada señal?
- ¿El score es de usuario, host, archivo o alerta?
- ¿La confianza es alta o baja?
- ¿Hay actividad posterior que lo sostenga?
- ¿Coincide con otras fuentes?
- ¿Hay ticket o cambio que lo explique?
- ¿El activo es crítico o no crítico?

Errores comunes al usar scores

✘ Escalar solo porque el score es alto
✘ Cerrar solo porque el score bajó
✘ No leer evidencia cruda del caso
✘ No revisar si el modelo tiene contexto del cambio
✘ Ignorar contradicciones entre fuentes
✘ No documentar por qué se aceptó o cuestionó el score
✘ Asumir que el modelo conoce el contexto operativo

7.6 | Caso: evidencia contradictoria en archivo (EDR vs VirusTotal)

Las fuentes pueden no coincidir. El analista debe priorizar evidencia técnica y contexto:

```
EDR: Malware detected
VirusTotal: 0/70 detections
Firma: No firmada
Path: C:\Users\Public\update.exe
Parent: powershell.exe
Created by: WINWORD.EXE chain
After: Scheduled task + external beaconing
```

Análisis esperado:

- No descartar por VT 0/70 — hash puede ser nuevo
- La ruta y cadena WINWORD→PS→Public son sospechosas
- Persistencia + beaconing pesan más que VT
- Escalar y preservar muestra
- Buscar alcance por hash y dominio

VirusTotal 0/70 no descarta el malware cuando el hash es nuevo o personalizado. Lo que sí pesa: cadena WINWORD→PS→Public + tarea programada + beaconing. La evidencia de comportamiento supera la falta de firma AV.

7.6 | Caso: reputación maliciosa en IP cloud compartida

La reputación de una IP no siempre indica un problema real — el contexto cambia todo:

```
Alert: Connection to malicious IP
IP: 104.26.14.x
Reputation: Malicious (Threat Intel feed)
Action: Allowed
Process: chrome.exe
User: diseño.torres
Time: 14:32 (business hours)
Activity: Normal browsing session
```

Análisis esperado:

- 104.26.14.x es rango de Cloudflare CDN
- IPs cloud compartidas alojan miles de sitios
- Un sitio malicioso puede compartir IP con legítimos
- Revisar el DOMINIO, no solo la IP
- ¿Qué sitio visitó? ¿Qué dominio se resolvió?
- Combinar con el proceso y actividad del usuario

Conclusión: La IP tiene mala reputación porque algún sitio malicioso la compartió. Eso no significa que diseño.torres visitó ese sitio. Buscar el dominio en logs del proxy o DNS antes de escalar.

Regla práctica: para evaluar reputación de IP, siempre buscar el dominio consultado. Una IP de CDN compartida (Cloudflare, Fastly, Akamai, AWS) no puede analizarse sin saber el hostname destino.

7.6 | Caso: IA vs evidencia técnica

Cuando IA y evidencia se contradicen, se revisa la evidencia:

```
IA classification: Benign
Reason: known admin user

Logs:
User: soporte.admin
Parent: WINWORD.EXE
CommandLine: powershell -nop -w hidden -enc
Network: docs-preview-check.net
Ticket: Not found
```

Decisión esperada:

- El usuario técnico no alcanza para cerrar
- Parent process y command line aumentan sospecha
- Sin ticket, no hay validación operativa
- La IA puede estar sobreponderando el rol
- Escalar o investigar con prioridad

La IA clasificó 'Benign' porque el usuario es admin. Pero WINWORD→PS -enc sin ticket es siempre sospechoso, sin importar quién sea el usuario. La IA estaba sobreponderando el rol.